# 信息安全测评与风险评估

8.2 威胁识别与赋值

授课教师：张玉



# 目录

CONTENTS


01 案例导入——“一句日志引发的全球警报”

02 学习目标

03 复习回顾——风险评估三要素

04 什么是威胁？（定义）

# 案例导入——“一句日志引发的全球警报”

## 一行日志文本，让全球无数服务器一夜沦陷——这不是电影情节。



### 核心问题：

- 一个“平平无奇”的日志功能，为什么能引发全球十级警报？

**漏洞引爆**
一行日志文本即可执行任意代码

**影响范围**
从Minecraft到全球企业核心系统

**全球警报**
披露数小时内即遭全球扫描利用

**根本原因**
Log4j藏在十亿级设备依赖链深处

**课末回收**

学完威胁赋值，请回来给 Log4Shell 打分——你打的分数，就是当年全球应急的警报等级。

# 学习目标

通过本课学习，你将能够：

1. **理解**：威胁在风险评估中的定义与作用
2. **掌握**：威胁源的分类方法（人为威胁 vs 环境威胁）
3. **掌握**：威胁赋值的等级标准与判断依据
4. **能够**：独立完成威胁识别表与威胁赋值
5. **理解**：威胁识别与资产识别、脆弱性识别的关联关系

# 复习回顾——风险评估三要素

**风险评估核心公式：风险 = 资产价值 × 威胁可能性 × 脆弱性严重程度**

三者的关系：威胁利用脆弱性，对资产造成损害。

**资产**

对组织有价值的东西。有什么需要保护？

**威胁**

可能导致资产损失的事件。谁/什么可能造成破坏？

**脆弱性**

资产中可被利用的弱点。有什么漏洞可被利用？

**本课重点： 威胁识别与赋值——回答“谁/什么可能造成破坏？”这个问题。**

# 什么是威胁？（定义）

**威胁的定义：**可能导致信息资产遭受损害、破坏或未经授权访问的事件、行为或环境因素。

**通俗理解：**威胁 = “可能造成破坏的力量或事件”（可能是黑客、火灾、病毒等）

## 威胁 vs 脆弱性（重要区别）



### 威胁

主体/事件。类比**“想要破门而入的坏人”**



### 脆弱性

资产弱点。类比**“门锁的质量问题”**



### 风险

造成的后果。类比**“造成的损失”**

# 威胁识别——核心任务

**威胁识别的目标：**对信息资产面临的威胁进行全面的标识和分析。

**威胁识别的四大任务：**

1. **识别威胁源**
   找出谁/什么可能对资产造成威胁
2. **分析威胁方式**
   威胁可能以什么方式发生
3. **评估威胁频率**
   威胁发生的可能性有多大
4. **威胁赋值**
   给威胁发生的频率打分（1–5级）

# 威胁源的分类方法

**两类威胁源：** 人为威胁 + 环境威胁

| | | |
|---|---|---|
| **人为威胁** | **恶意攻击** | 黑客攻击、内部人员恶意破坏、竞争对手 |
| | **非恶意/意外** | 误操作、配置错误、管理疏忽 |
| | **社会工程** | 钓鱼邮件、冒充身份、欺骗 |
| **环境威胁** | **自然灾害** | 地震、洪水、雷击、火灾 |
| | **环境因素** | 温湿度异常、电力中断、电磁干扰 |
| | **系统故障** | 硬件故障、软件缺陷、网络中断 |

# 人为威胁——深入分析

人为威胁是当前最主要、最复杂的威胁来源。按动机分类：

## 黑客攻击

**动机：**经济利益、政治目的、炫耀

**典型行为：**漏洞利用、DoS攻击、数据窃取

危害极高

## 内部恶意

**动机：**报复、经济利益

**典型行为：**数据泄露、系统破坏

危害高

## 外部间谍

**动机：**窃取商业/国家机密

**典型行为：**APT攻击、社会工程

危害极高

## 误操作

**动机：**无恶意、过失

**典型行为：**误删数据、错误配置

危害中~高

## 管理疏忽

**动机：**安全意识不足

**典型行为：**弱口令、未及时打补丁

危害中

# 环境威胁——不可忽视的因素

环境威胁虽不常见，但一旦发生后果往往极其严重。



### 自然灾害（如地震、洪水、台风）

影响物理设备、机房，需采取灾备、异地备份等防范措施。



### 电力故障（如断电、电压不稳）

影响服务器、网络设备，需配备UPS、发电机。



### 电磁干扰（如强电磁场）

影响通信线缆、存储介质，需采取屏蔽、隔离措施。



### 火灾（如电气火灾、雷击起火）

影响全部设备、数据，需配备消防系统、灭火器。



### 温湿度异常（如过热、结露）

影响精密设备，需配备精密空调、监控。